

A Cibersegurança Básica Falha nas Empresas ?

Introdução

A ponte entre a teoria das grandes certificações de segurança e a trincheira do suporte diário de TI costuma expor uma realidade frustrante. Enquanto o mercado foca em ferramentas complexas para mitigar ameaças cibernéticas avançadas, a verdade é que a cibersegurança básica falha nas empresas por motivos muito mais estruturais.

Na rotina da infraestrutura, onde cada dia é um novo desafio de governança, fica claro que o perigo real raramente é um ataque altamente sofisticado. O risco mora na ausência de processos essenciais: desde o momento em que setores de negócios contratam softwares externos sem qualquer validação da equipe técnica, até a negligência com a segurança física dos ativos, onde o controle do ambiente crítico é ignorado. De nada adianta dominar as melhores práticas e se preparar intensamente para estruturar defesas sólidas se a organização sustenta uma cultura de "apaga-fogo", onde o setor passa 100% do tempo reagindo a incidentes cotidianos e ignorando documentações.

Pilares de falhas

1. **O Fenômeno do Shadow IT (Sistemas Fantasma):** Quando setores de negócios contratam plataformas, CRMs ou softwares externos sem qualquer validação, homologação ou consulta prévia ao setor de TI. O resultado? Os pilares da Tríade CID (Confidencialidade, Integridade e Disponibilidade) não funcionem antes mesmo do sistema entrar no ar. Se o TI não sabe que o sistema existe, como poderá garantir a segurança e dar suporte aos usuários?

- 1.1. **O Dado Real:** Estudos de mercado compilados pela **Gartner** indicam que o investimento em *Shadow IT* (softwares e soluções adquiridas por outros setores sem o conhecimento do departamento de tecnologia) representa rotineiramente entre **30% e 40%** de todos os gastos com tecnologia em empresas de grande e médio porte.

- 1.2. **O Impacto:** O grande problema é que a falta de centralização e homologação multiplica os riscos de brechas de conformidade regulatória (como a LGPD) e vazamentos de dados.

2. **O Offboarding Silencioso (Risco de Identidade):** Um colaborador é desligado em um dia e o TI só descobre semanas depois — ou pior, quando ocorre um incidente de segurança. Sem um fluxo de comunicação integrado e obrigatório entre o RH e a Infraestrutura, credenciais corporativas permanecem ativas com equipamentos nas mãos de quem já não faz parte do quadro. Contas órfãs são uma das principais portas de entrada para vazamentos de dados.

2.1. **O Dado Real:** O relatório global *Cost of a Data Breach*, publicado anualmente pela **IBM Security**, aponta que o roubo ou o comprometimento de credenciais válidas (como contas de ex-funcionários que não foram revogadas a tempo) figura consistentemente entre os **principais vetores iniciais de ataque** mais utilizados por cibercriminosos.

2.2. **O Impacto:** Invasões iniciadas por credenciais comprometidas são as mais difíceis de detectar, levando uma média assustadora de **246 a 292 dias** para a equipe conseguir identificar e conter totalmente a ação do invasor, gerando prejuízos milionários.

3. **O Princípio do "Acesso Total" e Permissões Bagunçadas:** Estruturas de pastas na rede e níveis de acesso no sistema de gestão onde qualquer usuário visualiza quase tudo. O *Princípio do Menor Privilégio* (dar ao usuário apenas o acesso estritamente necessário para sua função) é frequentemente ignorado para "evitar burocracia". Muitas vezes, as organizações só decidem arrumar os acessos críticos e auditar a rede quando um olhar externo ou um grande susto com dados sensíveis chama a atenção da diretoria.

3.1. **O Dado Real:** Uma amostragem massiva de auditoria realizada pela empresa de segurança **Varonis** (que analisou bilhões de arquivos em centenas de empresas) revelou que, em média, **65% das organizações possuem mais de 1.000 arquivos confidenciais abertos para absolutamente todos os colaboradores** devido a permissões globais mal configuradas.

3.2. **O Impacto:** Quando o princípio do menor privilégio não é aplicado, qualquer credencial comum que seja comprometida abre as portas para que um atacante (ou um *ransomware*) se mova lateralmente e neutralize os servidores da empresa.

4. **A Segurança Física Esquecida:** De nada adianta investir em criptografia se a segurança física dos ativos críticos é negligenciada. Permitir a circulação de pessoal não autorizado na sala do servidor para "guardar materiais", ignorar a necessidade de manutenção elétrica adequada (substituindo-a por paliativos improvisados) ou não possuir prevenção elementar contra incêndios no local mais crítico da empresa é flertar com o desastre.

4.1. **O Dado Real:** Conforme o *Data Center Physical Security Report* e as diretrizes de controle ambiental do **SANS Institute**, falhas em perímetros físicos e a ausência de sistemas básicos de prevenção de sinistros (como gerenciamento elétrico e supressão de incêndio) respondem por uma parcela crítica das paradas não planejadas de infraestrutura. A pesquisa aponta que permitir o desvio de função de salas de servidores (utilizando-as como depósito) eleva o risco de acidentes e anula os controles de acesso lógico, já que a segurança digital depende diretamente da integridade física do hardware.

4.2. **O Impacto:** Quando a empresa falha em aplicar os controles de Proteção Física e Ambiental (como os previstos na norma **NIST SP 800-53**), ela quebra diretamente o pilar da **Disponibilidade**. Sem um ambiente climatizado, eletricamente isolado e protegido contra incêndios por agentes limpos (gás inerte), a operação inteira fica vulnerável a um Ponto Único de Falha (SPOF). Se o hardware queimar ou sofrer um sinistro físico por falta de prevenção, nenhum sistema de segurança digital ou criptografia do mundo conseguirá manter a empresa no ar.

5. **A Cultura do "Apaga-Fogo" vs. Chamados Formais:** Ambientes onde as demandas operacionais ignoram sistemas de chamados ("passa lá na nossa sala que a gente resolve") destroem a capacidade analítica da TI. Sem documentação, histórico ou métricas, o setor passa 100% do tempo reagindo a incidentes cotidianos. Como consequência, projetos de melhoria estrutural e segurança nunca saem do papel, forçando a equipe a gerenciar a infraestrutura na base da fé e da boa vontade, e não de um Plano de Continuidade de Negócios (BCP).

5.1. **O Dado Real:** O índice de maturidade digital *Cybersecurity Readiness Index*, desenvolvido pela **Cisco**, avalia o nível de resiliência de milhares de empresas ao redor do mundo. Os dados indicam que uma fatia extremamente reduzida das organizações (apenas **um dígito a 15%**, dependendo do ano fiscal e do pilar de identidade avaliado) atinge o nível considerado "Maduro" em suas defesas. A esmagadora maioria opera em níveis iniciais ou formativos.

5.2. **O Impacto:** Menos de 35% dos líderes de tecnologia sentem real confiança de que suas estruturas atuais resistiriam de forma resiliente a um ataque sem sofrer interrupções críticas de negócios.

Referências Bibliográficas

- **Cisco Cybersecurity Readiness Index.** Cisco.
https://newsroom.cisco.com/c/dam/r/newsroom/en/us/interactive/cybersecurity-readiness-index/2025/documents/2025_Cisco_Cybersecurity_Readiness_Index.pdf.
Acesso em: 07 mai. 2026
- **Data Breach Statistics & Trends.** Varonis.
<https://www.varonis.com/blog/data-breach-statistics>. Acesso em: 13 mai. 2026
- **Data Center Physical Security Checklist.** GIAC.
<https://www.giac.org/research-papers/416>. Acesso em: 21 abr. 2026
- **How much is shadow IT costing your organization?** <https://shadowitcost.com/>.
Acesso em: 04 jun. 2026
- **How to eliminate enterprise shadow IT.** CIO.
<https://www.cio.com/article/234745/how-to-eliminate-enterprise-shadow-it.html>.
Acesso em: 01 jun. 2026
- **New Cisco Study Finds Only 15% of Companies Surveyed are Ready to Defend Against Cybersecurity Threats.** Cisco.
<https://investor.cisco.com/news/news-details/2023/New-Cisco-Study-Finds-Only-15-of-Companies-Surveyed-are-Ready-to-Defend-Against-Cybersecurity-Threats/default.aspx>. Acesso em: 04 jun. 2026